



# Web Application Vulnerability Assessment Using OWASP ZAP

## Project :- Prerna Bhashani

Automated and Manual Security Testing of web Application in Controlled Lab Environment.



# Introduction

## What is Web Application Security ?

Web application security focuses on identifying vulnerabilities in website and web services that could be exploited by attackers.

## What is OWASP ZAP ?

OWASP ZAP is an open - source web application security scanner developed by OWASP

it is widely used by penetration testers to detect vulnerabilities

# Lab Environment Setup

Machine used

Attacker Machine

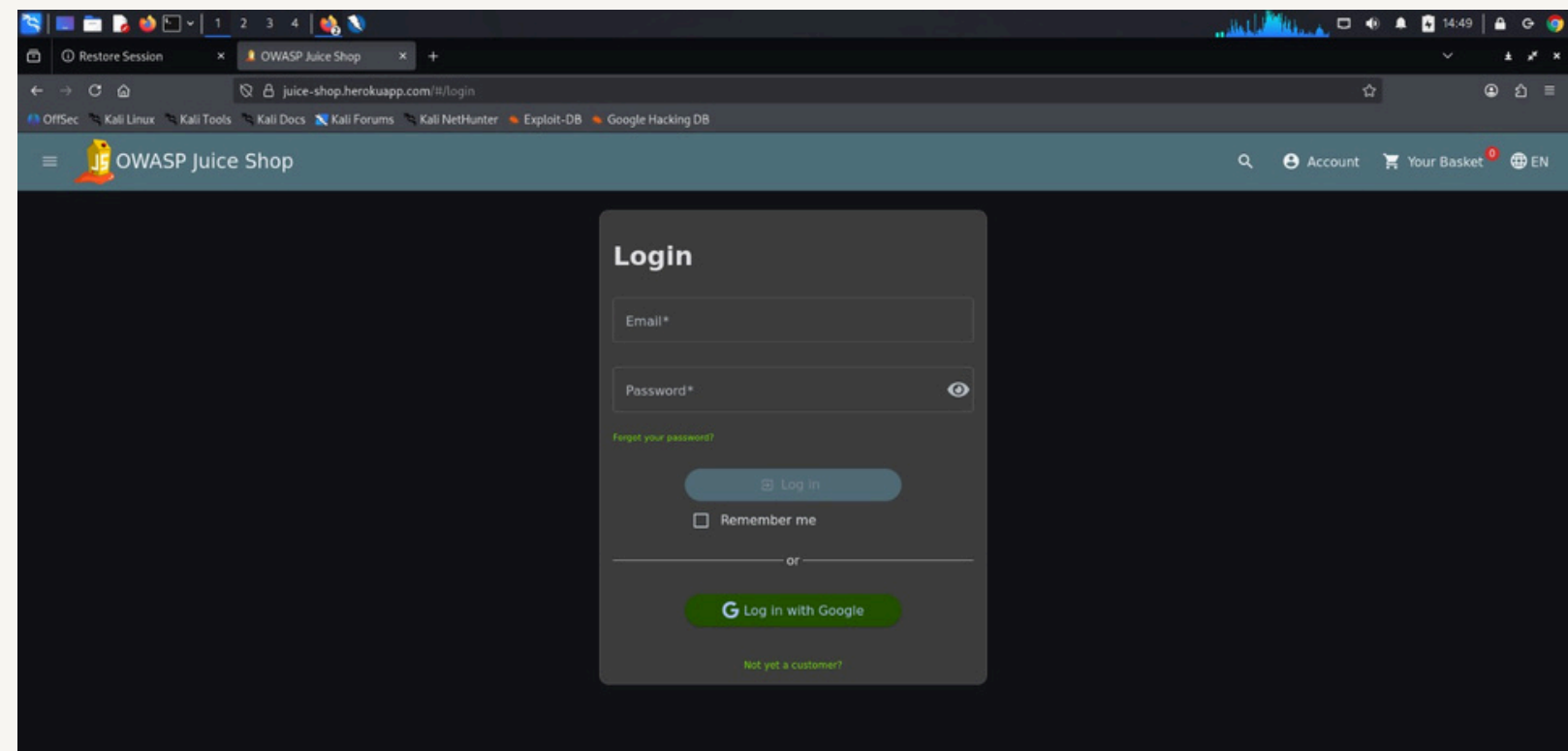
Kali Linux

Target Application

Vulnerable Web Application  
(owasp juice shop)

Network setup

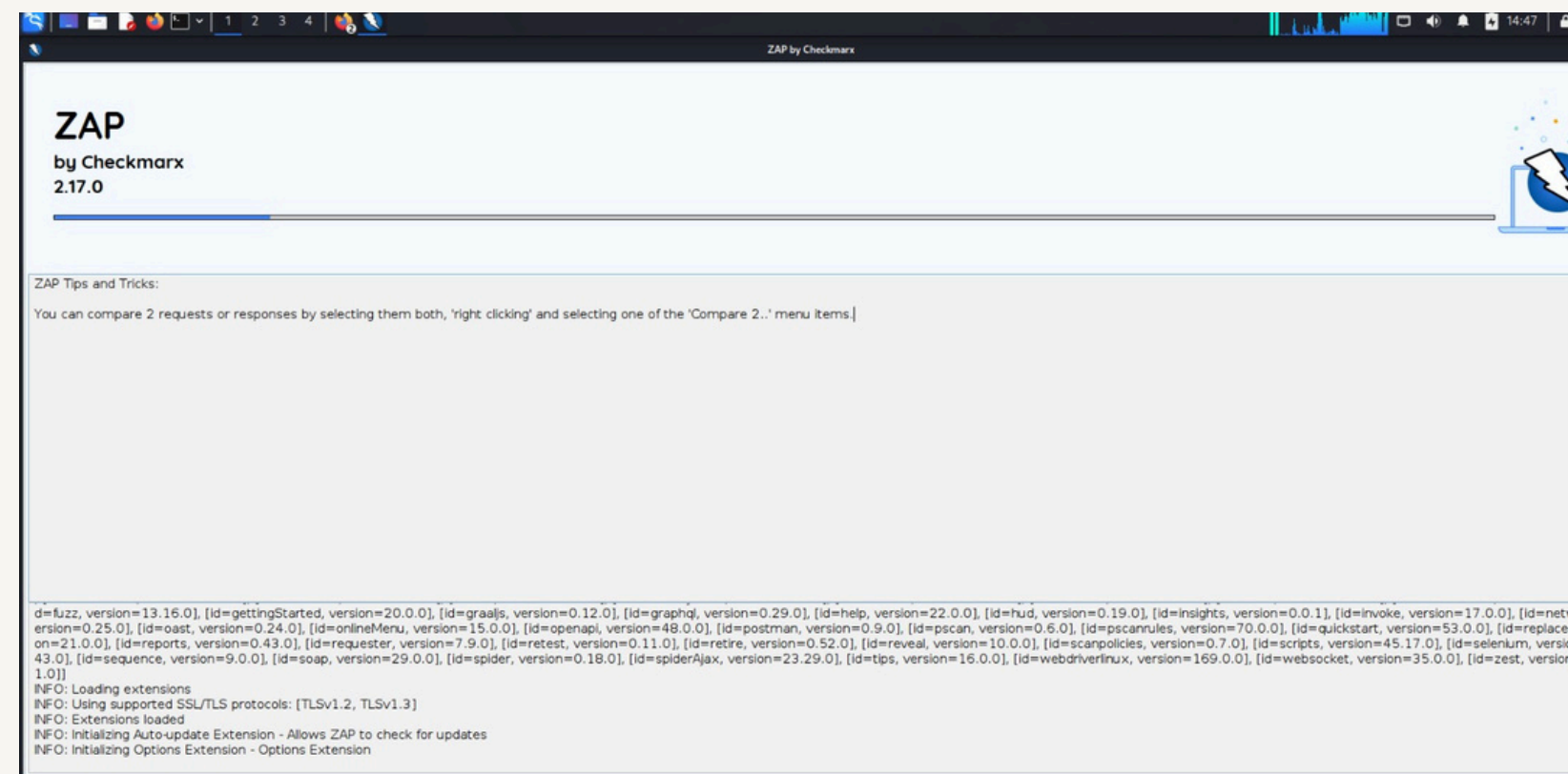
Host-only network for safe  
testing.



# Tools Used

## Primary Tool

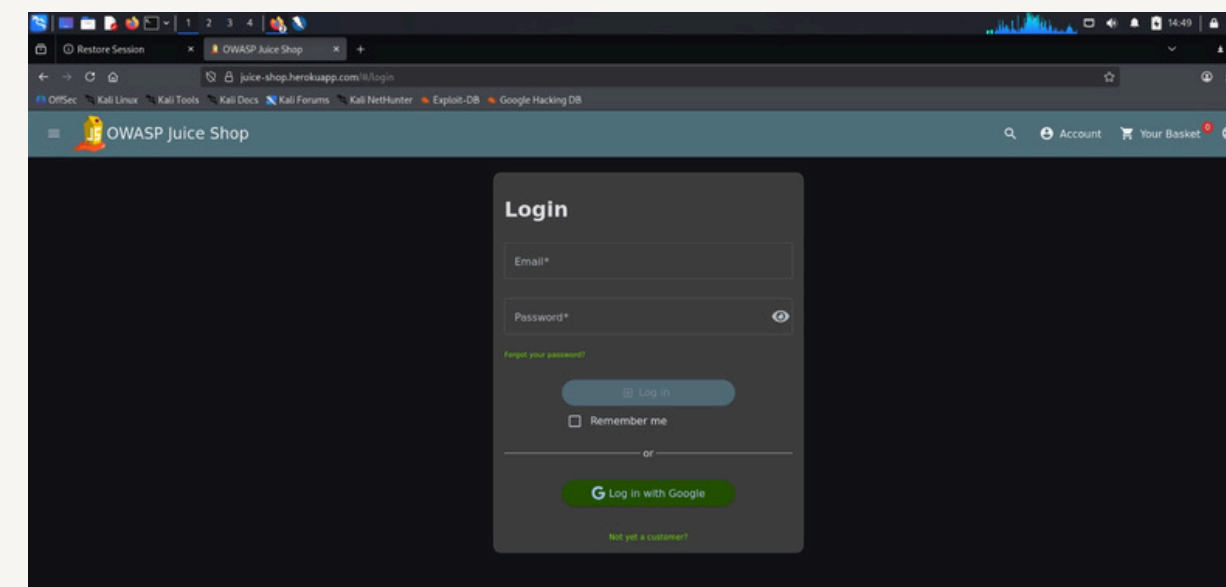
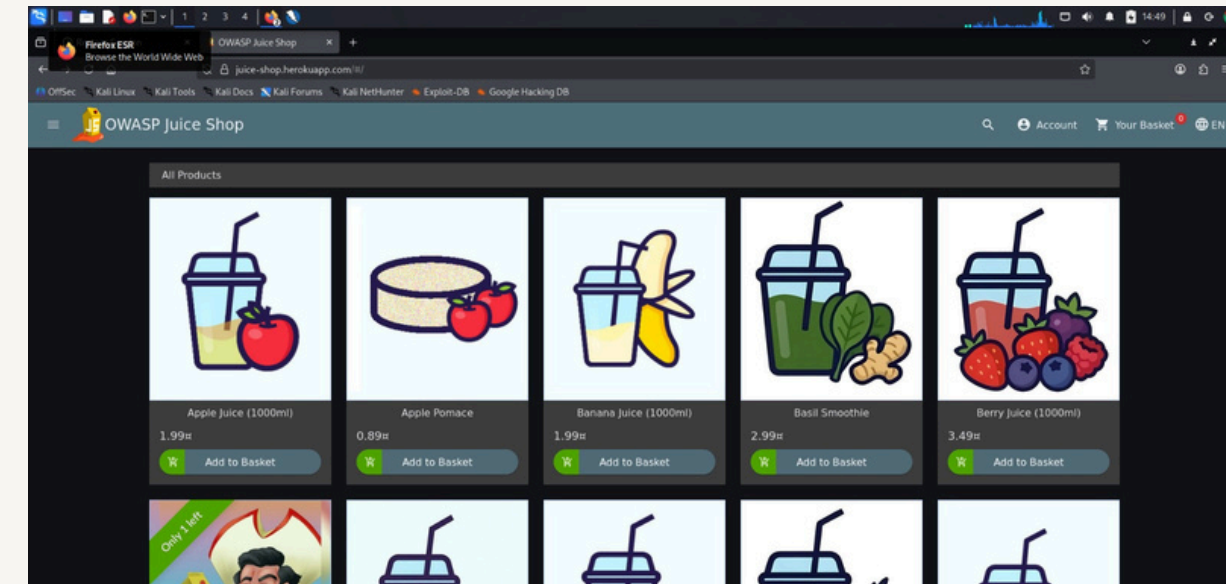
OWASP ZAP



# Target Application Setup

## Steps Performed

- 1.Installed Vulnerable web application
- 2.Configured database
- 3.Enable debugging and testing mode
- 4.Verified application accessibility





# Proxy Configuration Objective

## Objective

Capture web application traffic

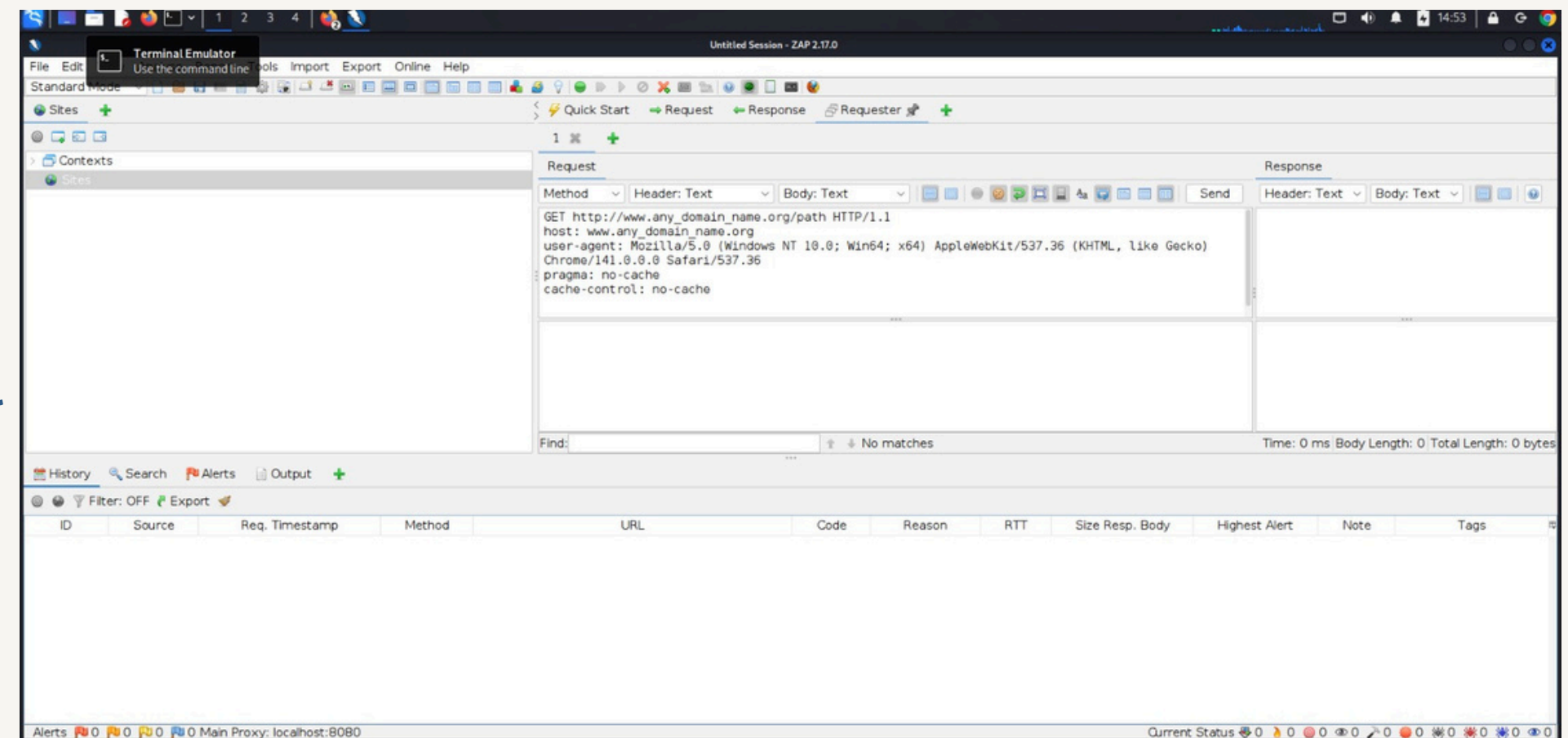
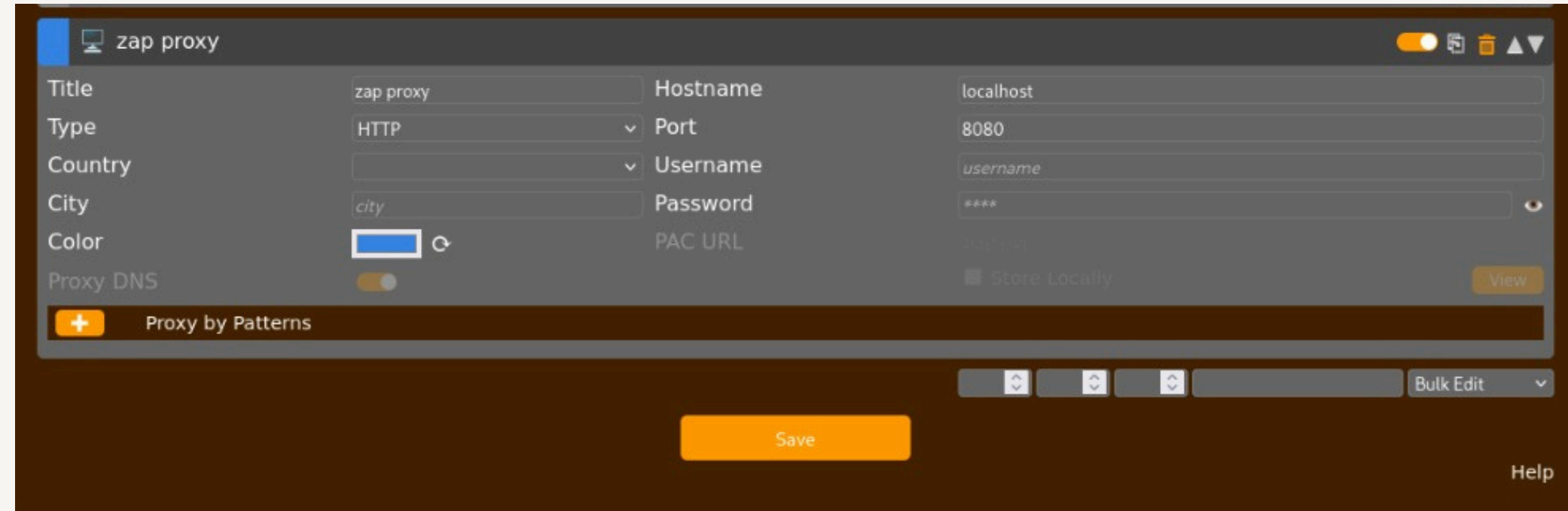
## steps

1. Configure browser proxy

2. Connect browser with OWASP ZAP

3. Intercept HTTP requests

4. Analyse request and response data



# Automated Vulnerability Scanning

# Objective

## Perform automated vulnerability detection

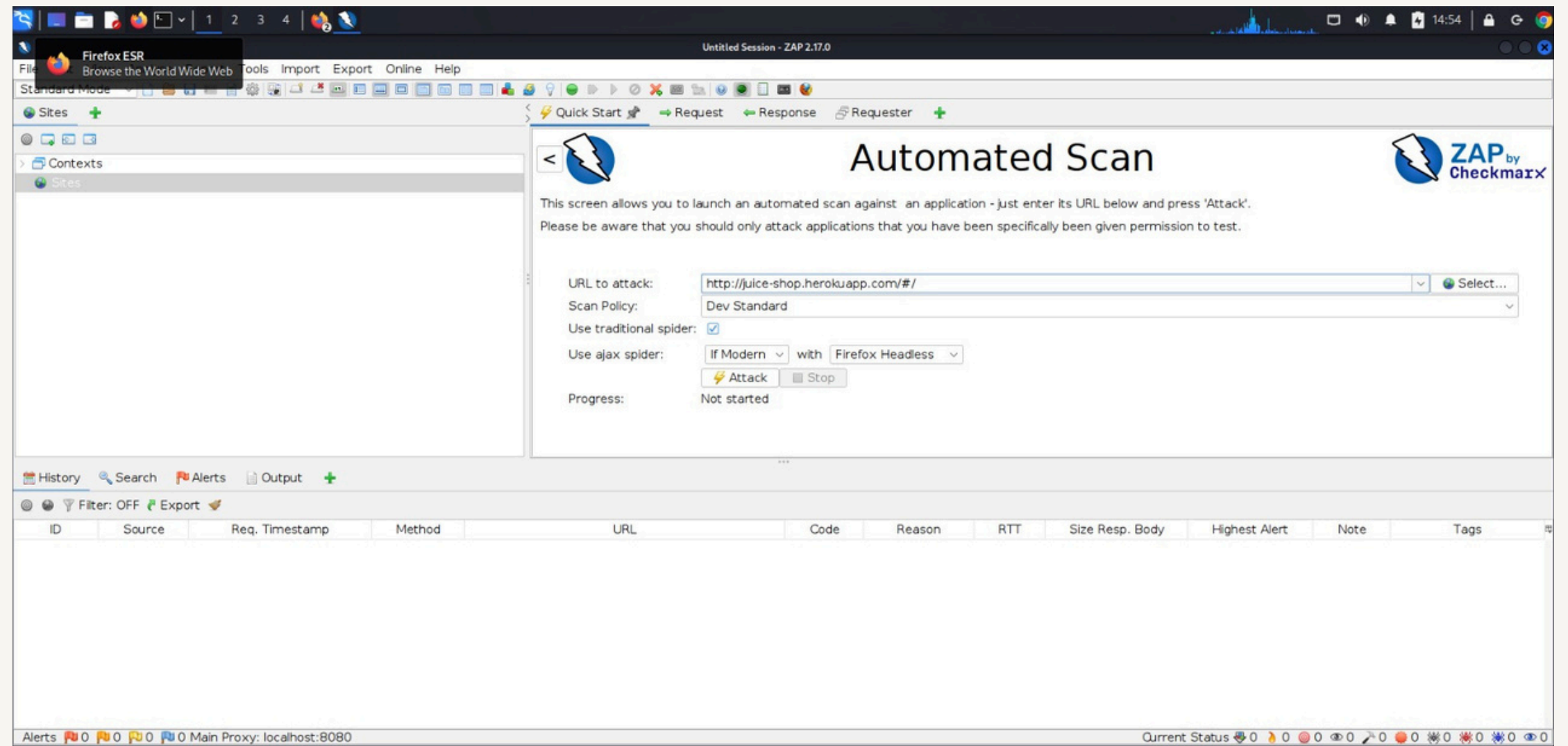
# Steps

## Added target URL in ZAP

## Started automated spider scan

## Performed active vulnerability

## Generated scan result



# Vulnerabilities Detected (Alerts)

The screenshot displays the ZAP 2.17.0 interface during an automated scan. The main window is titled "Automated Scan" and includes the ZAP by Checkmarx logo. It provides instructions on how to launch a scan and a warning about testing permissions. The configuration section shows the URL "http://juice-shop.herokuapp.com/#/", the "Dev Standard" scan policy, and the use of a traditional spider and an ajax spider with Firefox Headless. The "Attack" button is highlighted, and the progress indicates the ajax spider is discovering content.

URL to attack:

Scan Policy:

Use traditional spider: ☒

Use ajax spider:  with

Progress: Using ajax spider to discover the content

The bottom panel shows the "Alerts" tab with a list of 10 detected vulnerabilities:

- Content Security Policy (CSP) Header Not Set
- Cross-Domain Misconfiguration (Systemic)
- Missing Anti-clickjacking Header
- Session ID in URL Rewrite (3)
- Private IP Disclosure
- Strict-Transport-Security Header Not Set
- Timestamp Disclosure - Unix (Systemic)
- X-Content-Type-Options Header Missing (4)
- Modern Web Application (Systemic)
- Retrieved from Cache

Full details of any selected alert will be displayed here.

You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.

You can also edit existing alerts by double clicking on them.



# Manual Testing Phase

## Objective

Verify Vulnerabilities manually

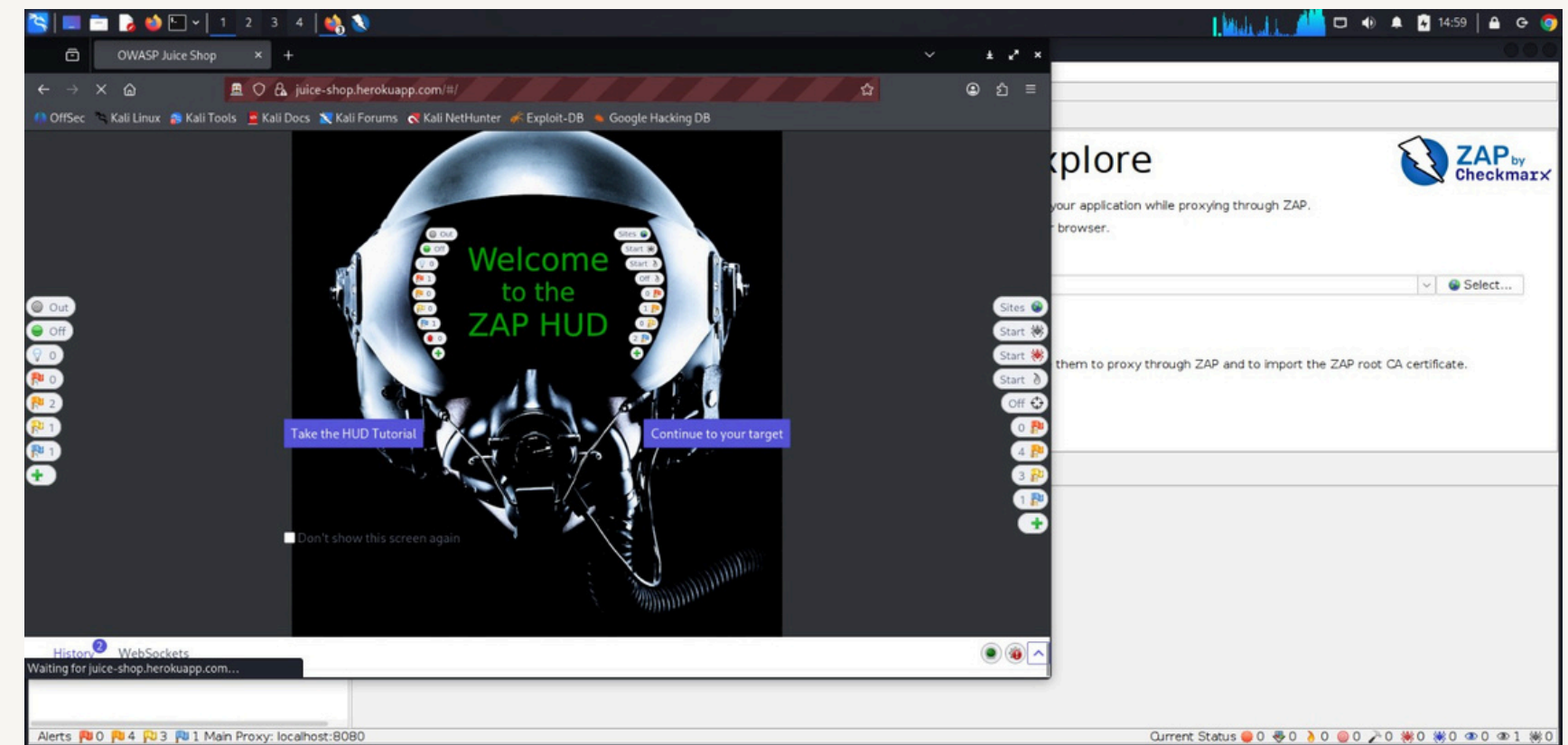
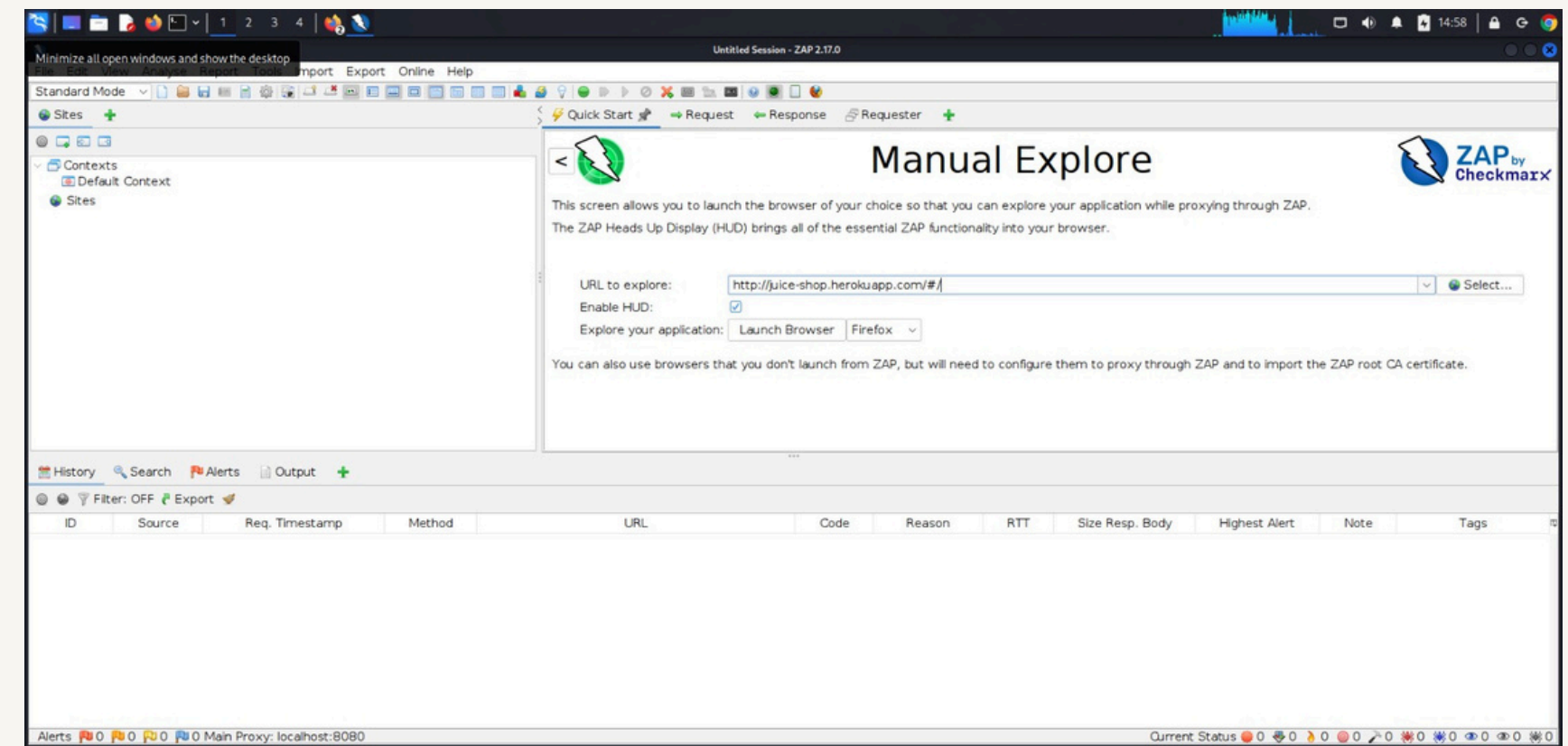
## Activities

Modified HTTP request

Tested authentication bypass

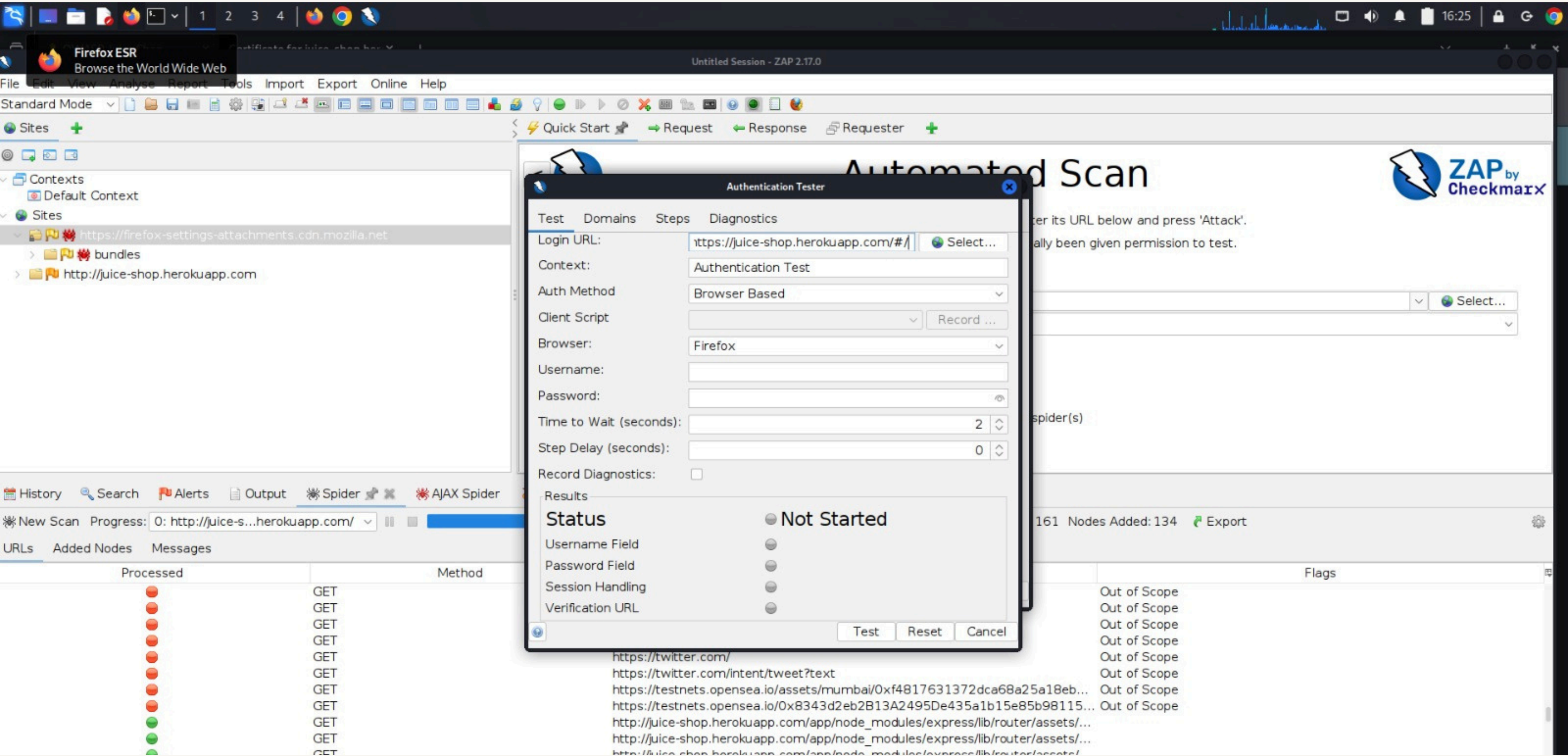
Input validation testing

Session testing





# Authentication Weakness Testing



# Vulnerability Risk Classification

## Risk Levels

### High Risk

### Medium Risk

### Low Risk

### Informational

## Explanation

Helps organization security fixes

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

| Alert type                                                   | Risk          | Count         |
|--------------------------------------------------------------|---------------|---------------|
| <a href="#">Content Security Policy (CSP) Header Not Set</a> | Medium        | 5<br>(71.4%)  |
| <a href="#">Cross-Domain Misconfiguration</a>                | Medium        | 5<br>(71.4%)  |
| <a href="#">Strict-Transport-Security Header Not Set</a>     | Low           | 1<br>(14.3%)  |
| <a href="#">Timestamp Disclosure - Unix</a>                  | Low           | 8<br>(114.3%) |
| <a href="#">X-Content-Type-Options Header Missing</a>        | Low           | 1<br>(14.3%)  |
| <a href="#">Modern Web Application</a>                       | Informational | 5<br>(71.4%)  |
| <a href="#">Retrieved from Cache</a>                         | Informational | 1<br>(14.3%)  |
| Total                                                        |               | 7             |

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

| Level | Reason        | Site                                                 | Description                                                        | Statistic |
|-------|---------------|------------------------------------------------------|--------------------------------------------------------------------|-----------|
| Low   | Warning       |                                                      | ZAP warnings logged - see the zap.log file for details             | 1         |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of responses with status code 2xx                       | 96 %      |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of responses with status code 4xx                       | 3 %       |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of endpoints with content type application/javascript   | 10 %      |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of endpoints with content type application/octet-stream | 3 %       |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of endpoints with content type image/x-icon             | 1 %       |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of endpoints with content type text/css                 | 1 %       |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of endpoints with content type text/html                | 81 %      |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of endpoints with content type text/markdown            | 2 %       |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of endpoints with content type text/plain               | 1 %       |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of endpoints with method GET                            | 100 %     |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Count of total endpoints                                           | 137       |
| Info  | Informational | http://juice-shop.herokuapp.com                      | Percentage of slow responses                                       | 100 %     |
| Info  | Informational | https://firefox-settings-attachments.cdn.mozilla.net | Percentage of responses with status code 2xx                       |           |
| Info  | Informational | https://firefox-settings-attachments.cdn.mozilla.net | Percentage of endpoints with content type app                      |           |
| Info  | Informational | https://firefox-settings-attachments.cdn.mozilla.net | Percentage of endpoints with method GET                            |           |
| Info  | Informational | https://firefox-settings-attachments.cdn.mozilla.net | Count of total endpoints                                           | 1         |
| Info  | Informational | https://firefox-settings-attachments.cdn.mozilla.net | Percentage of slow responses                                       | 100 %     |

# Mitigation Strategies

## Security Recommendations

Implement input validation

Use prepared SQL statement

Apply secure authentication methods

Enable HTTPS encryption

Regular security testing



# Project Outcomes

## Skills Demonstrated

Web application penetration testing

Automated vulnerability scanning

Manual vulnerability verification

Security risk assessment

Report generation

# Real World Importance

Web application are major cyber attack targets

This project prepares professionals for role such as:

Web security Analyst

Penetration Tester

Security Auditor

## Ethical consideration

All testing was conducted in controlled environment for educational and research purposes only.